
ENGENHARIA DE COMPUTAÇÃO

Disciplina: Engenharia de Software

KA 13 — Segurança de Software

(Software Security)

Documento de Análise de Segurança, OWASP e Conformidade LGPD

Instituição de Ensino	UNOESC
Professor(a) Responsável	Odemir Moreira da Mata Jr.
Disciplina	Engenharia de Software
Turma / Semestre	JBA620-6
Integrantes do Grupo	Ana Clara Viganó Prestes de Oliveira, Davi Antônio Basotto Minati, Elian Baldasso Pereira Duarte, Jasmine Masson Alves, Lucas Eduardo Heydt, Vitória Aparecida Vendausen
Data de Entrega	24/06/2026

Histórico de Versões

Versão	Data	Autor(es)	Descrição	Revisado por
v1.0	24/04/2026	Ana Clara	Modelagem inicial de ameaças STRIDE.	Jasmine Alves
v1.1	08/05/2026	Elian Duarte	Inclusão dos controles OWASP e LGPD.	Davi Minati

1. Introdução

1.1 Escopo da Análise de Segurança

Este documento estabelece as diretrizes arquiteturais e operacionais de proteção de dados para o sistema de gestão clínica. O escopo abrange a identificação de ameaças aos microserviços, modelagem de segurança nas camadas de rede, aplicação e banco de dados, e a mitigação de vulnerabilidades sistêmicas. O foco principal é a proteção de Prontuários Eletrônicos de Pacientes (PEP), garantindo os princípios de Confidencialidade, Integridade e Disponibilidade (Triade CIA).

1.2 Referências — OWASP Top 10, STRIDE, LGPD

A estratégia de segurança baseia-se em três pilares metodológicos:

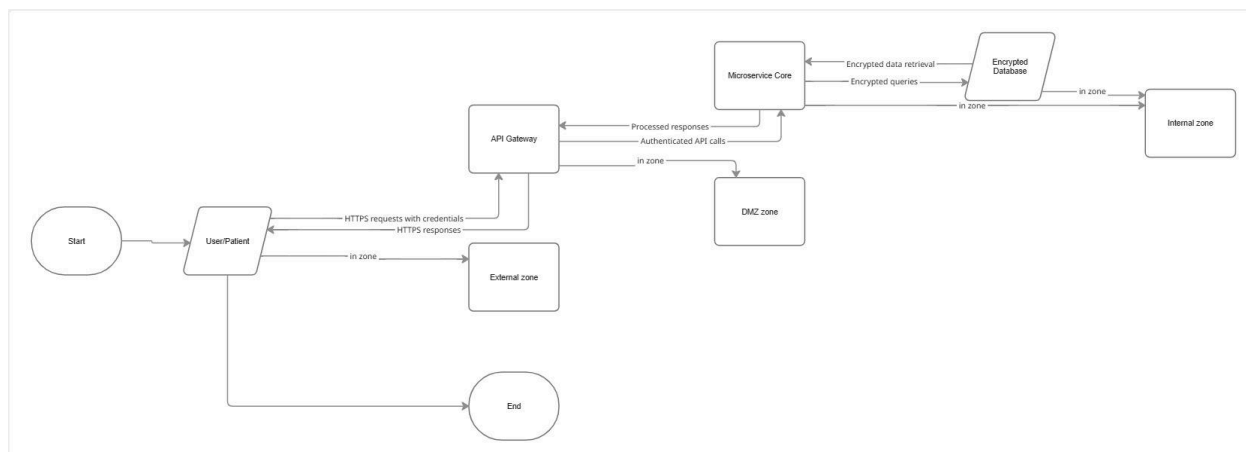
- OWASP Top 10 (2021): Padrão da indústria para mitigação das vulnerabilidades mais críticas em aplicações web.
- Microsoft STRIDE: Framework de modelagem de ameaças focado na decomposição de componentes e fluxos de dados.
- LGPD (Lei nº 13.709/2018): Base legal brasileira, com foco rigoroso no Artigo 5º (Dados Sensíveis), Artigo 11º (Tratamento de Dados de Saúde) e Artigo 46º (Medidas de Segurança Técnicas).

2. Análise de Ameaças — Metodologia STRIDE

2.1 Aplicação do STRIDE ao Sistema de Consultório

A metodologia STRIDE foi aplicada durante a fase de design (Shift-Left Security) para mapear vetores de ataque nas interfaces do sistema. A análise categoriza as ameaças em: **S**poofing (Falsificação de Identidade), **T**ampering (Adulteração de Dados), **R**epudiation (Repúdio), **I**nformation Disclosure (Divulgação de Informações), **D**enial of Service (Negação de Serviço) e **E**levation of Privilege (Elevação de Privilégio). Cada rota da API e tabela de banco de dados foi avaliada contra essas seis categorias para gerar os controles de mitigação presentes no catálogo.

2.2 Diagrama de Fluxo de Dados (DFD) para Threat Modeling (inserir)



2.3 Catálogo de Ameaças Identificadas

As ameaças descobertas na modelagem do DFD foram documentadas e classificadas de acordo com o risco (Alto, Médio, Baixo), servindo como base para a criação de tarefas no backlog de segurança (DevSecOps). O catálogo detalhado encontra-se na seção de Tabelas deste documento

3. Checklist OWASP Top 10

4. Conformidade LGPD no Design de Segurança

4.1 Mapeamento de Dados Pessoais e Sensíveis Tratados

4.2 Controles Técnicos Obrigatórios

4.3 Direitos dos Titulares de Dados (Art. 18 LGPD)

4.4 Relatório de Impacto à Proteção de Dados (RIPD) — simplificado

Tabelas e Formulários

Catálogo de Ameaças STRIDE

ID	Categoria STRIDE	Ameaça Identificada	Componente Afetado	Risco (A/M/B)	Controle de Mitigação

| Checklist OWASP Top 10

#	Vulnerabilidade OWASP	Manifestação no Sistema	Controle de Design Proposto	Risco Residual

| Mapeamento de Dados Pessoais — LGPD

Dado	Classificação (Comum/Sensível)	Onde Armazenado	Quem Acessa	Base Legal (Art. LGPD)	Controle Aplicado

| Observações e Referências Consultadas

OWASP (Open Worldwide Application Security Project): OWASP Top 10:2021. Consulta aos vetores de ameaça A01 a A10 para implementação de defesas ativas na arquitetura web.

Lei Geral de Proteção de Dados Pessoais (LGPD): Lei nº 13.709/2018, Brasil. Foco analítico nos direitos dos titulares (Art. 18) e nos requisitos excepcionais para tratamento de dados sensíveis de tutela da saúde (Art. 11, II).

SWEBOK v4.0 (Guide to the Software Engineering Body of Knowledge): IEEE Computer Society. Consulta focada no *Chapter 14: Software Security*, aplicando princípios de design seguro, modelagem de ameaças e mitigação de vulnerabilidades sistêmicas.

Microsoft Threat Modeling: Metodologia STRIDE adotada para decomposição e identificação de anomalias estruturais nos processos de autenticação e rede.

ISO/IEC 27001 e 27701: Referências fundamentais sobre Sistemas de Gestão da Segurança da Informação e extensão para privacidade da informação.